

ORTHRUS SECURITY REPORT

API Penetration Testing Report

Target:

<https://petstore3.swagger.io/api/v3/openapi.json>

Scan Date: 2026-06-02 21:58:45

Legal & Confidentiality Disclaimer

This report is STRICTLY CONFIDENTIAL and its distribution is subject to restriction. It is intended solely for authorized personnel. It is generated by an automated security testing tool (Orthrus). The tool assigns a theoretical Base CVSS score which may not reflect the environmental or temporal context of the vulnerability. The authors and the tool itself are not liable for any missed vulnerabilities, critical flaws that were not detected, or subsequent compromises of the tested systems. This tool is provided for authorized security testing only.

Methodology & Scoring Criteria

This report presents the findings of an automated Dynamic Application Security Testing (DAST) scan. The scan involved sending various malicious payloads and unexpected inputs to the target API to identify security vulnerabilities.

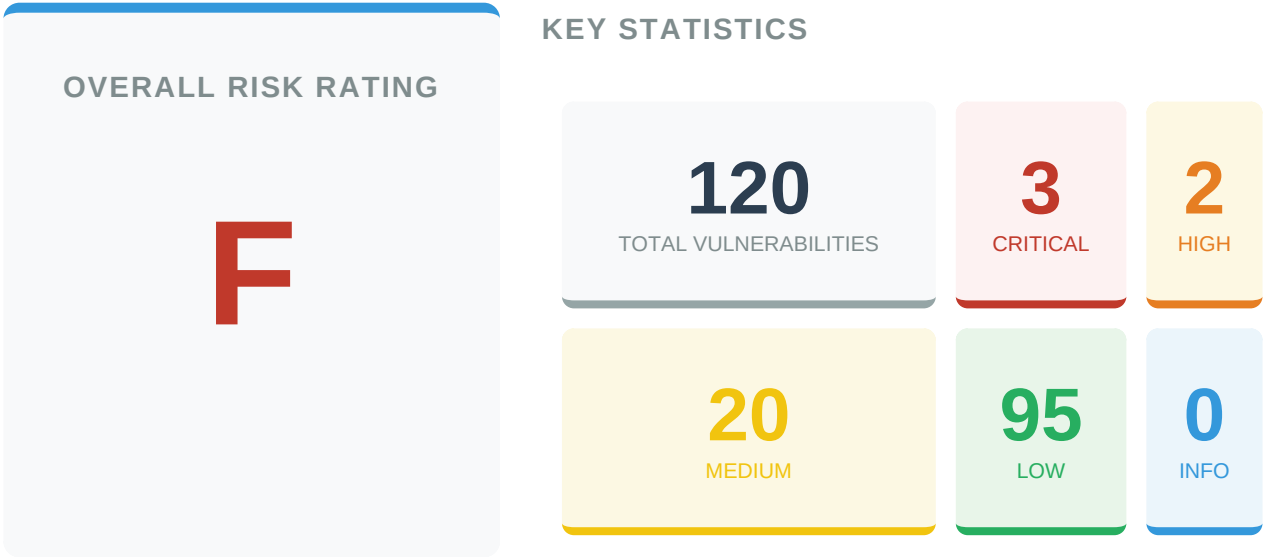
Methodology and Standards

Standard	Application
OWASP API Security Top 10	API-specific vulnerability classification & testing guidelines
OWASP Top 10 (2021)	Primary web vulnerability classification framework
CVSS v3.1	Common Vulnerability Scoring System for objective severity rating
CWE / CAPEC	Common Weakness Enumeration and Attack Pattern tracking
Automated DAST Assessment	Dynamic payload injection, fuzzing, and unauthenticated/authenticated state evaluation

Security Grade Definition

- A** Excellent security posture. No high or critical vulnerabilities detected.
- B** Good security posture. Minor vulnerabilities present, but no immediate critical threats.
- C** Fair security posture. Several medium vulnerabilities or a single high vulnerability require attention.
- D** Poor security posture. Multiple high vulnerabilities detected. Urgent remediation needed.
- F** Critical failure. One or more critical vulnerabilities detected, exposing the application to immediate and severe risks.

1. Global Summary



- CRITICAL:** Critical risk vulnerabilities indicate a severe and immediate threat to the application's security. They can typically be exploited without authentication and can lead to full system compromise or significant data breach. Immediate remediation is required.
- HIGH:** High risk vulnerabilities pose a significant threat. They often require some level of access or complex exploitation but can result in major data theft or system disruption. They should be addressed as a high priority.
- MEDIUM:** Medium risk vulnerabilities represent a moderate threat. They usually require specific preconditions or authorized access to be exploited. While not immediately critical, they should be fixed in the next scheduled update.
- LOW:** Low risk vulnerabilities have a minimal impact. They might expose non-sensitive information or require highly unlikely scenarios to exploit. They should be addressed when resources permit.
- INFO:** Informational findings do not represent a direct vulnerability but highlight security best practices that could be improved to strengthen the overall security posture.

2. Vulnerability Summary

Each finding is scored under both CVSS v3.1 (for parity with NVD, CISA KEV, and most vendor advisories) and CVSS v4.0 (current FIRST standard since November 2023). Severity bands are identical across both versions. Detailed finding entries include full v3.1 and v4.0 vectors. Scores reflect what the original engagement recorded; vectors are documented for reproducibility against the FIRST CVSS calculator.

Severity Distribution

Severity	Count	CVSS Range (v3.1 / v4.0)	Remediation Priority
CRITICAL	3	9.0 to 10.0	Immediate (before next release)
HIGH	2	7.0 to 8.9	Within 1 sprint cycle
MEDIUM	20	4.0 to 6.9	Within 2 sprint cycles
LOW	95	0.1 to 3.9	Next quarterly review
INFO	0	0.0	Best practice recommendation

3. Detailed Findings

Missing Authentication for Critical Function

Severity: **CRITICAL** **Base CVSS Score:** 9.8 **CWE:** CWE_306
CAPEC Reference: CAPEC-115
OWASP: A07:2025 - Authentication Failures
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE `https://petstore3.swagger.io/api/v3/pet/{petId}`

Description

The endpoint exposes sensitive operations without requiring authentication.

Evidence

Endpoint returned 200 OK OK without any authentication credentials

Request:

```
Sent DELETE request without Authorization header.
```

Response:

```
Status: 200 OK  
Body snippet: Pet deleted
```

Remediation

Implement robust authentication for this endpoint.

Missing Authentication for Critical Function

Severity:

CRITICAL

Base CVSS Score:
9.8

CWE: CWE_306
CAPEC Reference: CAPEC-115
OWASP: A07:2025 - Authentication Failures
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST https://petstore3.swagger.io/api/v3/store/order

Description

The endpoint exposes sensitive operations without requiring authentication.

Evidence

Endpoint returned 200 OK OK without any authentication credentials

Request:

Sent POST request without Authorization header.

Response:

Status: 200 OK
Body snippet: {"id":0,"petId":0,"quantity":0,"complete":false}

Remediation

Implement robust authentication for this endpoint.

Missing Authentication for Critical Function

Severity:

CRITICAL

Base CVSS Score:
9.8

CWE: CWE_306
CAPEC Reference: CAPEC-115
OWASP: A07:2025 - Authentication Failures
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The endpoint exposes sensitive operations without requiring authentication.

Evidence

Endpoint returned 200 OK OK without any authentication credentials

Request:

Sent DELETE request without Authorization header.

Response:

Status: 200 OK
Body snippet:

Remediation

Implement robust authentication for this endpoint.

Potential Broken Function Level Authorization

Severity:

HIGH

Base CVSS Score:
9.8

CWE: CWE_285
CAPEC Reference: CAPEC-115
OWASP: A01:2025 - Broken Access Control
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET `https://petstore3.swagger.io/api/v3/pet/{petId}`

Description

The endpoint accepts administrative HTTP methods (like DELETE) even though it was discovered as a GET endpoint. Verify if the current user should have this privilege.

Evidence

Server returned 200 OK OK when sending a DELETE request to a GET endpoint.

Request:

Sent DELETE request to `https://petstore3.swagger.io/api/v3/pet/26`

Response:

Status: 200 OK

Remediation

Ensure function-level access control checks exist for all administrative operations and methods.

Potential Broken Function Level Authorization

Severity:

HIGH

Base CVSS Score:

9.8

CWE: CWE_285

CAPEC Reference: CAPEC-115

OWASP: A01:2025 - Broken Access Control

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The endpoint accepts administrative HTTP methods (like DELETE) even though it was discovered as a GET endpoint. Verify if the current user should have this privilege.

Evidence

Server returned 200 OK OK when sending a DELETE request to a GET endpoint.

Request:

Sent DELETE request to <https://petstore3.swagger.io/api/v3/store/order/13>

Response:

Status: 200 OK

Remediation

Ensure function-level access control checks exist for all administrative operations and methods.

Sensitive Information in Query String

Severity:

MEDIUM

Base CVSS Score:

6.5

CWE: CWE_598

CAPEC Reference: CAPEC-87

OWASP: A04:2025 - Cryptographic Failures

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/user/login>

Description

The endpoint accepts a parameter named 'password' in the URL query string. Query strings are logged by reverse proxies, web servers, and browser histories, leading to sensitive data exposure.

Evidence

Parameter 'password' found in GET request.

Request:

URL requested: <https://petstore3.swagger.io/api/v3/user/login> with parameter password

Response:

Status: Static Analysis (No request sent)

Body snippet: Not applicable. This vulnerability is detected statically from the API schema /specification.

Remediation

Move sensitive data from the query string to HTTP Headers (e.g., Authorization header) or the request body (e.g., POST request).

Reflected Cross-Site Scripting (XSS)

Severity:

MEDIUM

Base CVSS Score:

6.1

CWE: CWE_79

CAPEC Reference: CAPEC-63

OWASP: A05:2025 - Injection

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The endpoint reflects unencoded user input from query param 'status' into the response.

Evidence

Response contains the exact unencoded XSS payload. The response is not HTML, so the script won't execute directly in modern browsers, but could be dangerous if a frontend incorrectly inserts this JSON data into the DOM.

Request:

```
Injected XSS payload into query param: status=<script>alert('XSS_VULNAPI_TEST')</script>
```

Response:

```
Status: 400 BAD_REQUEST
Content-Type: application/json
Body snippet: {"code":400,"message":"Input error: query parameter `status` value `
```

Remediation

Contextually encode user input before reflecting it in responses. Ensure the Content-Type header is strictly set to application/json for APIs.

Potential Broken Object Level Authorization (BOLA)

Severity:

MEDIUM

Base CVSS Score:

7.5

CWE: CWE_639

CAPEC Reference: CAPEC-17

OWASP: A01:2025 - Broken Access Control

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint returned a successful response when the resource ID was modified from 82 to 83. Ensure the authenticated user has permission to access this specific object.

Evidence

Response status 200 OK when accessing ID 83

Request:

Modified URL from <https://petstore3.swagger.io/api/v3/pet/82> to <https://petstore3.swagger.io/api/v3/pet/83>

Response:

Status: 200 OK

Remediation

Implement strict authorization checks at the object level. Verify the user requesting the data owns or has roles to access it.

Potential Broken Object Level Authorization (BOLA)

Severity:

MEDIUM

Base CVSS Score:

7.5

CWE: CWE_639

CAPEC Reference: CAPEC-17

OWASP: A01:2025 - Broken Access Control

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint returned a successful response when the resource ID was modified from 82 to 81. Ensure the authenticated user has permission to access this specific object.

Evidence

Response status 200 OK when accessing ID 81

Request:

Modified URL from <https://petstore3.swagger.io/api/v3/pet/82> to <https://petstore3.swagger.io/api/v3/pet/81>

Response:

Status: 200 OK

Remediation

Implement strict authorization checks at the object level. Verify the user requesting the data owns or has roles to access it.

Potential Cross-Site Request Forgery (CSRF)

Severity:

MEDIUM

Base CVSS Score:
6.5

CWE: CWE_352
CAPEC Reference: CAPEC-62
OWASP: A01:2025 - Broken Access Control
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The state-changing endpoint allowed a request originating from an untrusted Origin without requiring an explicit Anti-CSRF token in the headers. If this API relies on Cookie-based authentication, it is vulnerable to CSRF.

Evidence

Server accepted the request with Origin: <https://malicious-website.com> and no CSRF tokens.

Request:

Sent DELETE request stripped of CSRF headers and injected Origin: <https://malicious-website.com>.

Response:

Status: 200 OK
Body snippet: Pet deleted

Remediation

Implement Anti-CSRF tokens (Synchronizer Token Pattern) for all state-changing endpoints if using Cookie authentication. Ensure cookies have the SameSite=Lax or Strict attribute.

Potential Cross-Site Request Forgery (CSRF)

Severity:

MEDIUM

Base CVSS Score:
6.5

CWE: CWE_352
CAPEC Reference: CAPEC-62
OWASP: A01:2025 - Broken Access Control
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST `https://petstore3.swagger.io/api/v3/store/order`

Description

The state-changing endpoint allowed a request originating from an untrusted Origin without requiring an explicit Anti-CSRF token in the headers. If this API relies on Cookie-based authentication, it is vulnerable to CSRF.

Evidence

Server accepted the request with Origin: `https://malicious-website.com` and no CSRF tokens.

Request:

Sent POST request stripped of CSRF headers and injected Origin: `https://malicious-website.com`.

Response:

Status: 200 OK
Body snippet: `{"id":0,"petId":0,"quantity":0,"complete":false}`

Remediation

Implement Anti-CSRF tokens (Synchronizer Token Pattern) for all state-changing endpoints if using Cookie authentication. Ensure cookies have the SameSite=Lax or Strict attribute.

Potential Mass Assignment (BOPLA)

Severity:

MEDIUM

Base CVSS Score:

6.5

CWE: CWE_915

CAPEC Reference: CAPEC-17

OWASP: A08:2025 - Software or Data Integrity Failures

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** <https://petstore3.swagger.io/api/v3/store/order>

Description

The endpoint accepts unexpected fields (e.g., 'is_admin', 'role') in the JSON payload without returning a validation error.

Evidence

Server returned 200 OK OK after injecting privilege escalation fields into the JSON payload.

Request:

```
Injected fields into JSON body: {"data":"perspiciatis","is_admin":true,"isAdmin":true,"role":"admin","permissions":"all"}
```

Response:

Status: 200 OK

Remediation

Use DTOs (Data Transfer Objects) to explicitly map accepted fields. Avoid binding HTTP requests directly to domain models or database entities.

Potential Cross-Site Request Forgery (CSRF)

Severity:

MEDIUM

Base CVSS Score:
6.5

CWE: CWE_352
CAPEC Reference: CAPEC-62
OWASP: A01:2025 - Broken Access Control
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The state-changing endpoint allowed a request originating from an untrusted Origin without requiring an explicit Anti-CSRF token in the headers. If this API relies on Cookie-based authentication, it is vulnerable to CSRF.

Evidence

Server accepted the request with Origin: <https://malicious-website.com> and no CSRF tokens.

Request:

Sent DELETE request stripped of CSRF headers and injected Origin: <https://malicious-website.com>.

Response:

Status: 200 OK
Body snippet:

Remediation

Implement Anti-CSRF tokens (Synchronizer Token Pattern) for all state-changing endpoints if using Cookie authentication. Ensure cookies have the SameSite=Lax or Strict attribute.

Missing Rate Limiting

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_799

CAPEC Reference: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST <https://petstore3.swagger.io/api/v3/pet>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Evidence

After 30 requests, the server returned status 500 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 500 INTERNAL_SERVER_ERROR

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: b1801a53b4f1ab56)"}
```

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_799

CAPEC Reference: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PUT <https://petstore3.swagger.io/api/v3/pet>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Evidence

After 30 requests, the server returned status 500 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 500 INTERNAL_SERVER_ERROR

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: d2a9975fe0e95b28)"}

```

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_799

CAPEC Reference: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** `https://petstore3.swagger.io/api/v3/pet/{petId}`

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Evidence

After 30 requests, the server returned status 404 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 404 NOT_FOUND

Body snippet: Pet not found

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_799

CAPEC Reference: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Evidence

After 30 requests, the server returned status 200 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 200 OK
Body snippet: Pet deleted

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_799

CAPEC Reference: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** `https://petstore3.swagger.io/api/v3/pet/{petId}/uploadImage`

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Evidence

After 30 requests, the server returned status 400 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 400 BAD_REQUEST
Body snippet: No file uploaded

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_799

CAPEC Reference: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** <https://petstore3.swagger.io/api/v3/store/order>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Evidence

After 30 requests, the server returned status 200 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 200 OK

Body snippet: {"id":0,"petId":0,"quantity":0,"complete":false}

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_799

CAPEC Reference: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Evidence

After 30 requests, the server returned status 200 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 200 OK
Body snippet:

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_799

CAPEC Reference: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST <https://petstore3.swagger.io/api/v3/user>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Evidence

After 30 requests, the server returned status 500 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 500 INTERNAL_SERVER_ERROR

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 582e8bff6805510a)"}

```

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_799

CAPEC Reference: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/user/login>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Evidence

After 30 requests, the server returned status 200 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 200 OK

Body snippet: Logged in user session: 2528042575920632511

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_799

CAPEC Reference: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Evidence

After 30 requests, the server returned status 400 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 400 BAD_REQUEST

Body snippet: {"code":400,"message":"Input error: unable to convert input to io.swagger.petstore.model.User[]"}

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_799

CAPEC Reference: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Evidence

After 30 requests, the server returned status 500 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 500 INTERNAL_SERVER_ERROR

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 4e3affa969d33c22)"}

```

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Rate Limiting

Severity:

MEDIUM

Base CVSS Score:

5.3

CWE: CWE_799

CAPEC Reference: CAPEC-115

OWASP: A06:2025 - Insecure Design

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PUT <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The endpoint does not seem to enforce rate limiting. 30 rapid requests were sent without receiving a 429 Too Many Requests response.

Evidence

After 30 requests, the server returned status 500 instead of 429.

Request:

Sent 30 identical requests in rapid succession.

Response:

Status: 500 INTERNAL_SERVER_ERROR

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 1a0da6db873885e0)"}
```

Remediation

Implement rate limiting using a gateway, WAF, or application logic (e.g. token bucket algorithm).

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Headers received: [Date:"Tue, 02 Jun 2026 19:58:47 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 8e2788791518d374)"}

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Headers received: [Date:"Tue, 02 Jun 2026 19:58:47 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 8e2788791518d374)"}

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_1021

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 19:58:47 GMT", Content-Type:"application/json", Content-
Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-
Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key,
Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.
v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged
(ID: 8e2788791518d374)"}

```

Headers received: [Date:"Tue, 02 Jun 2026 19:58:47 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 8e2788791518d374)"}

```

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

```

Headers received: [Date:"Tue, 02 Jun 2026 19:58:47 GMT", Content-Type:"application/json", Content-
Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-
Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key,
Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.
v20231009)"]

```

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 8e2788791518d374)"}

```

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Severity:

LOW

Base CVSS Score:

3.7

CWE: CWE_200

CAPEC Reference: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST <https://petstore3.swagger.io/api/v3/pet>

Description

The server leaks version information or technology stack details via the 'Server' header.

Evidence

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard POST request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Server: Jetty(9.4.53.v20231009)

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 8e2788791518d374)"}}
```

Remediation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PUT <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard PUT request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Headers received: [Date:"Tue, 02 Jun 2026 19:58:47 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: c5f5a99f29d908f1)"}

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: PUT https://petstore3.swagger.io/api/v3/pet

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard PUT request.

Response:

Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 19:58:47 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: c5f5a99f29d908f1)"}

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_1021
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PUT <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard PUT request.

Response:

Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 19:58:47 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: c5f5a99f29d908f1)"}

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PUT <https://petstore3.swagger.io/api/v3/pet>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard PUT request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Headers received: [Date:"Tue, 02 Jun 2026 19:58:47 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: c5f5a99f29d908f1)"}

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Severity:

LOW

Base CVSS Score:

3.7

CWE: CWE_200

CAPEC Reference: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PUT <https://petstore3.swagger.io/api/v3/pet>

Description

The server leaks version information or technology stack details via the 'Server' header.

Evidence

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard PUT request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Server: Jetty(9.4.53.v20231009)
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged
(ID: c5f5a99f29d908f1)"}
```

Server: Jetty(9.4.53.v20231009)

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: c5f5a99f29d908f1)"}

```

Remediation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard GET request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-Length:"132", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":400,"message":"Input error: query parameter `status` value `et` is not in the allowable values `[available, pending, sold]`"}
```

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: GET https://petstore3.swagger.io/api/v3/pet/findByStatus

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-Length:"132", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":400,"message":"Input error: query parameter `status` value `et` is not in the allowable values `[available, pending, sold]`"}

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_1021

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-Length:"132", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":400,"message":"Input error: query parameter `status` value `et` is not in the allowable values `[available, pending, sold]`"}
```

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard GET request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-Length:"132", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":400,"message":"Input error: query parameter `status` value `et` is not in the allowable values `[available, pending, sold]`"}
```

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Severity:

LOW

Base CVSS Score:

3.7

CWE: CWE_200

CAPEC Reference: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/pet/findByStatus>

Description

The server leaks version information or technology stack details via the 'Server' header.

Evidence

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard GET request.

Response:

Status: 400 BAD_REQUEST
Server: Jetty(9.4.53.v20231009)
Body snippet: {"code":400,"message":"Input error: query parameter `status` value `et` is not in the allowable values `[available, pending, sold]`"}

Remediation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_693
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/xml", Content-Length:"13", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet not found

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_693
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET `https://petstore3.swagger.io/api/v3/pet/{petId}`

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/xml", Content-Length:"13", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet not found

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_1021
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/xml", Content-Length:"13", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet not found

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND

Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/xml", Content-Length:"13", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

Body snippet: Pet not found

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Severity:

LOW

Base CVSS Score:

3.7

CWE: CWE_200

CAPEC Reference: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Evidence

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND
Server: Jetty(9.4.53.v20231009)
Body snippet: Pet not found

Remediation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/pet/findByTags>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard GET request.

Response:

```
Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-Length:"2", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: []
```

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_693
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET https://petstore3.swagger.io/api/v3/pet/findByTags

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-Length:"2", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: []

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_1021

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/pet/findByTags>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

```
Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-Length:"2", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: []
```

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/pet/findByTags>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard GET request.

Response:

```
Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-
Length:"2", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-Methods:"
GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization",
Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: []
```

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Severity:

LOW

Base CVSS Score:

3.7

CWE: CWE_200

CAPEC Reference: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/pet/findByTags>

Description

The server leaks version information or technology stack details via the 'Server' header.

Evidence

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard GET request.

Response:

Status: 200 OK
Server: Jetty(9.4.53.v20231009)
Body snippet: []

Remediation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-Length:"11", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet deleted

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-Length:"11", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet deleted

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_1021

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-Length:"11", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet deleted

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-Length:"11", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet deleted

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Severity:

LOW

Base CVSS Score:

3.7

CWE: CWE_200

CAPEC Reference: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Evidence

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard DELETE request.

Response:

Status: 200 OK
Server: Jetty(9.4.53.v20231009)
Body snippet: Pet deleted

Remediation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 404 NOT_FOUND

Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/xml", Content-Length:"13", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

Body snippet: Pet not found

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_693
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 404 NOT_FOUND
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/xml", Content-Length:"13", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet not found

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_1021

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 404 NOT_FOUND
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/xml", Content-Length:"13", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Pet not found

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** <https://petstore3.swagger.io/api/v3/pet/{petId}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 404 NOT_FOUND

Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/xml", Content-Length:"13", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

Body snippet: Pet not found

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Severity:

LOW

Base CVSS Score:

3.7

CWE: CWE_200

CAPEC Reference: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** `https://petstore3.swagger.io/api/v3/pet/{petId}`

Description

The server leaks version information or technology stack details via the 'Server' header.

Evidence

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard POST request.

Response:

Status: 404 NOT_FOUND
Server: Jetty(9.4.53.v20231009)
Body snippet: Pet not found

Remediation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** `https://petstore3.swagger.io/api/v3/pet/{petId}/uploadImage`

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-
Length:"16", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-
Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key,
Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.
v20231009)"]
Body snippet: No file uploaded
```

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** `https://petstore3.swagger.io/api/v3/pet/{petId}/uploadImage`

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-
Length:"16", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-
Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key,
Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.
v20231009)"]
Body snippet: No file uploaded
```

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_1021
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST <https://petstore3.swagger.io/api/v3/pet/{petId}/uploadImage>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-Length:"16", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: No file uploaded

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** `https://petstore3.swagger.io/api/v3/pet/{petId}/uploadImage`

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-
Length:"16", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-
Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key,
Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.
v20231009)"]
Body snippet: No file uploaded
```

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Severity:

LOW

Base CVSS Score:

3.7

CWE: CWE_200

CAPEC Reference: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** `https://petstore3.swagger.io/api/v3/pet/{petId}/uploadImage`

Description

The server leaks version information or technology stack details via the 'Server' header.

Evidence

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard POST request.

Response:

Status: 400 BAD_REQUEST
Server: Jetty(9.4.53.v20231009)
Body snippet: No file uploaded

Remediation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/store/inventory>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: ad2fd98eb338b551)"}

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/store/inventory>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

```
Sent standard GET request.
```

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-
Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-
Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key,
Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.
v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged
(ID: ad2fd98eb338b551)"}

```

```

Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-
Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-
Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key,
Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.
v20231009)"]

```

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: ad2fd98eb338b551)"}

```

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_1021

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: GET https://petstore3.swagger.io/api/v3/store/inventory

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: ad2fd98eb338b551)"}

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/store/inventory>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: ad2fd98eb338b551)"}

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Severity:

LOW

Base CVSS Score:

3.7

CWE: CWE_200

CAPEC Reference: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/store/inventory>

Description

The server leaks version information or technology stack details via the 'Server' header.

Evidence

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

```
Sent standard GET request.
```

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Server: Jetty(9.4.53.v20231009)
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged
(ID: ad2fd98eb338b551)"}

```

Server: Jetty(9.4.53.v20231009)

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: ad2fd98eb338b551)"}

```

Remediation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** <https://petstore3.swagger.io/api/v3/store/order>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 200 OK

Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-Length:"48", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

Body snippet: {"id":0,"petId":0,"quantity":0,"complete":false}

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_693
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST https://petstore3.swagger.io/api/v3/store/order

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-Length:"48", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"id":0,"petId":0,"quantity":0,"complete":false}

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_1021

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** <https://petstore3.swagger.io/api/v3/store/order>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-Length:"48", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"id":0,"petId":0,"quantity":0,"complete":false}
```

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** <https://petstore3.swagger.io/api/v3/store/order>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 200 OK

Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/json", Content-Length:"48", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

Body snippet: {"id":0,"petId":0,"quantity":0,"complete":false}

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Severity:

LOW

Base CVSS Score:

3.7

CWE: CWE_200

CAPEC Reference: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** <https://petstore3.swagger.io/api/v3/store/order>

Description

The server leaks version information or technology stack details via the 'Server' header.

Evidence

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard POST request.

Response:

Status: 200 OK
Server: Jetty(9.4.53.v20231009)
Body snippet: {"id":0,"petId":0,"quantity":0,"complete":false}

Remediation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND

Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/xml", Content-Length:"15", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

Body snippet: Order not found

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND

Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/xml", Content-Length:"15", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

Body snippet: Order not found

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_1021

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/xml", Content-Length:"15", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Order not found

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND
Headers received: [Date:"Tue, 02 Jun 2026 19:58:48 GMT", Content-Type:"application/xml", Content-Length:"15", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Order not found

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Severity:

LOW

Base CVSS Score:

3.7

CWE: CWE_200

CAPEC Reference: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Evidence

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard GET request.

Response:

Status: 404 NOT_FOUND
Server: Jetty(9.4.53.v20231009)
Body snippet: Order not found

Remediation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST <https://petstore3.swagger.io/api/v3/user>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-
Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-
Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key,
Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.
v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged
(ID: 46e4c75b075baf57)"}
```

Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 46e4c75b075baf57)"}

```

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_693
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST <https://petstore3.swagger.io/api/v3/user>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 46e4c75b075baf57)"}]

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_1021

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** <https://petstore3.swagger.io/api/v3/user>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 46e4c75b075baf57)"}

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST <https://petstore3.swagger.io/api/v3/user>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

```

Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-
Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-
Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key,
Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.
v20231009)"]

```

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 46e4c75b075baf57)"}

```

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Severity:

LOW

Base CVSS Score:

3.7

CWE: CWE_200

CAPEC Reference: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST <https://petstore3.swagger.io/api/v3/user>

Description

The server leaks version information or technology stack details via the 'Server' header.

Evidence

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard POST request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Server: Jetty(9.4.53.v20231009)

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 46e4c75b075baf57)"}

```

Remediation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Length:"0", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet:

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Length:"0", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet:

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_1021

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Length:"0", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet:

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Length:"0", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet:

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Severity:

LOW

Base CVSS Score:

3.7

CWE: CWE_200

CAPEC Reference: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/store/order/{orderId}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Evidence

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard DELETE request.

Response:

Status: 200 OK
Server: Jetty(9.4.53.v20231009)
Body snippet:

Remediation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-
Length:"97", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-
Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key,
Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.
v20231009)"]
Body snippet: {"code":400,"message":"Input error: unable to convert input to io.swagger.petstore.
model.User[]"}

```

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_693
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST https://petstore3.swagger.io/api/v3/user/createWithList

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"97", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":400,"message":"Input error: unable to convert input to io.swagger.petstore.model.User[]"}

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_1021

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"97", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":400,"message":"Input error: unable to convert input to io.swagger.petstore.model.User[]"}
```

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: **POST** <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard POST request.

Response:

```
Status: 400 BAD_REQUEST
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-
Length:"97", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-
Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key,
Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.
v20231009)"]
Body snippet: {"code":400,"message":"Input error: unable to convert input to io.swagger.petstore.
model.User[]"}
```

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Severity:

LOW

Base CVSS Score:

3.7

CWE: CWE_200

CAPEC Reference: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: POST <https://petstore3.swagger.io/api/v3/user/createWithList>

Description

The server leaks version information or technology stack details via the 'Server' header.

Evidence

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard POST request.

Response:

```
Status: 400 BAD_REQUEST
Server: Jetty(9.4.53.v20231009)
Body snippet: {"code":400,"message":"Input error: unable to convert input to io.swagger.petstore.model.User[]"}
```

Remediation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: GET https://petstore3.swagger.io/api/v3/user/{username}

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 7608ddb14e4a8d0c)"}

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: GET https://petstore3.swagger.io/api/v3/user/{username}

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 7608ddb14e4a8d0c)"}

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_1021
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET https://petstore3.swagger.io/api/v3/user/{username}

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 7608ddb14e4a8d0c)"}

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

```
Sent standard GET request.
```

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-
Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-
Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key,
Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.
v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged
(ID: 7608ddb14e4a8d0c)"}

```

```

Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-
Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-
Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key,
Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.
v20231009)"]

```

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 7608ddb14e4a8d0c)"}

```

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Severity:

LOW

Base CVSS Score:

3.7

CWE: CWE_200

CAPEC Reference: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Evidence

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard GET request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Server: Jetty(9.4.53.v20231009)

Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 7608ddb14e4a8d0c)"}

Remediation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/user/login>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"43", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", X-Rate-Limit:"5000", X-Expires-After:"Tue Jun 02 20:58:58 UTC 2026", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Logged in user session: 6083522227736334061

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/user/login>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"43", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", X-Rate-Limit:"5000", X-Expires-After:"Tue Jun 02 20:58:58 UTC 2026", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Logged in user session: 6083522227736334061

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_1021

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/user/login>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"43", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", X-Rate-Limit:"5000", X-Expires-After:"Tue Jun 02 20:58:58 UTC 2026", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Logged in user session: 6083522227736334061

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/user/login>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"43", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", X-Rate-Limit:"5000", X-Expires-After:"Tue Jun 02 20:58:58 UTC 2026", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: Logged in user session: 6083522227736334061

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Severity:

LOW

Base CVSS Score:

3.7

CWE: CWE_200

CAPEC Reference: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/user/login>

Description

The server leaks version information or technology stack details via the 'Server' header.

Evidence

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard GET request.

Response:

Status: 200 OK
Server: Jetty(9.4.53.v20231009)
Body snippet: Logged in user session: 6083522227736334061

Remediation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/user/logout>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 200 OK

Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"15", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

Body snippet: User logged out

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_693
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/user/logout>

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"15", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: User logged out

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_1021

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/user/logout>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 200 OK
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"15", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: User logged out

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/user/logout>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard GET request.

Response:

Status: 200 OK

Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"15", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

Body snippet: User logged out

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Severity:

LOW

Base CVSS Score:

3.7

CWE: CWE_200

CAPEC Reference: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: GET <https://petstore3.swagger.io/api/v3/user/logout>

Description

The server leaks version information or technology stack details via the 'Server' header.

Evidence

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard GET request.

Response:

Status: 200 OK
Server: Jetty(9.4.53.v20231009)
Body snippet: User logged out

Remediation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_693
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PUT <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard PUT request.

Response:

Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: b3f12559792da271)"}

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:

4.3

CWE:

CWE_693

CAPEC Reference:

CAPEC-310

OWASP:

A02:2025 - Security Misconfiguration

Attack Vector:

API Endpoint (Network)

Technical Impact:

Unauthorized Access / Data Exposure

Endpoint: PUT https://petstore3.swagger.io/api/v3/user/{username}

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard PUT request.

Response:

Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: b3f12559792da271)"}

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_1021
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PUT <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard PUT request.

Response:

Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: b3f12559792da271)"}]

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:

4.3

CWE: CWE_693

CAPEC Reference: CAPEC-310

OWASP: A02:2025 - Security Misconfiguration

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PUT <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard PUT request.

Response:

Status: 500 INTERNAL_SERVER_ERROR

Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"*", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]

Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: b3f12559792da271)"}

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Severity:

LOW

Base CVSS Score:

3.7

CWE: CWE_200

CAPEC Reference: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: PUT <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Evidence

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard PUT request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Server: Jetty(9.4.53.v20231009)
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged
(ID: b3f12559792da271)"}

```

Server: Jetty(9.4.53.v20231009)

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: b3f12559792da271)"}

```

Remediation

Configure your web server to remove or mask the 'Server' header.

Missing Security Header: HSTS

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_693
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE `https://petstore3.swagger.io/api/v3/user/{username}`

Description

The HTTP response does not contain the 'Strict-Transport-Security' security header.

Evidence

Header 'Strict-Transport-Security' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 25a38232aa294638)"}

Remediation

Configure your web server or application framework to include the 'Strict-Transport-Security' header in all responses.

Missing Security Header: X-Content-Type-Options

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_693
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE `https://petstore3.swagger.io/api/v3/user/{username}`

Description

The HTTP response does not contain the 'X-Content-Type-Options' security header.

Evidence

Header 'X-Content-Type-Options' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 25a38232aa294638)"}]

Remediation

Configure your web server or application framework to include the 'X-Content-Type-Options' header in all responses.

Missing Security Header: X-Frame-Options

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_1021
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The HTTP response does not contain the 'X-Frame-Options' security header.

Evidence

Header 'X-Frame-Options' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 25a38232aa294638)"}]

Remediation

Configure your web server or application framework to include the 'X-Frame-Options' header in all responses.

Missing Security Header: CSP

Severity:

LOW

Base CVSS Score:
4.3

CWE: CWE_693
CAPEC Reference: CAPEC-310
OWASP: A02:2025 - Security Misconfiguration
Attack Vector: API Endpoint (Network)
Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE `https://petstore3.swagger.io/api/v3/user/{username}`

Description

The HTTP response does not contain the 'Content-Security-Policy' security header.

Evidence

Header 'Content-Security-Policy' is missing from the response.

Request:

Sent standard DELETE request.

Response:

Status: 500 INTERNAL_SERVER_ERROR
Headers received: [Date:"Tue, 02 Jun 2026 19:58:58 GMT", Content-Type:"application/json", Content-Length:"110", Connection:"keep-alive", Access-Control-Allow-Origin:"", Access-Control-Allow-Methods:"GET, POST, DELETE, PUT", Access-Control-Allow-Headers:"Content-Type, api_key, Authorization", Access-Control-Expose-Headers:"Content-Disposition", Server:"Jetty(9.4.53.v20231009)"]
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 25a38232aa294638)"}

Remediation

Configure your web server or application framework to include the 'Content-Security-Policy' header in all responses.

Information Exposure: Server Header

Severity:

LOW

Base CVSS Score:

3.7

CWE: CWE_200

CAPEC Reference: CAPEC-118

OWASP: Other - Other / Uncategorized

Attack Vector: API Endpoint (Network)

Technical Impact: Unauthorized Access / Data Exposure

Endpoint: DELETE <https://petstore3.swagger.io/api/v3/user/{username}>

Description

The server leaks version information or technology stack details via the 'Server' header.

Evidence

Header 'Server' reveals: Jetty(9.4.53.v20231009)

Request:

Sent standard DELETE request.

Response:

```
Status: 500 INTERNAL_SERVER_ERROR
Server: Jetty(9.4.53.v20231009)
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged
(ID: 25a38232aa294638)"}

```

Server: Jetty(9.4.53.v20231009)

```
Body snippet: {"code":500,"message":"There was an error processing your request. It has been logged (ID: 25a38232aa294638)"}

```

Remediation

Configure your web server to remove or mask the 'Server' header.